INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC103 – RISK ASSESSMENT AND MANAGEMENT TECHNIQUES

Module 1: Risk Identification Techniques

Role:Internal GRC Auditor

Lab 1: Practical Vulnerability Assessment for GRC Professionals Report

Student Name	Olubunmi Adesanmi
Registration number	C11/26/CGRCE 17550
Course	Grc 103-Risk Assessment and management techniques
Module	Risk Identification Techniques
Role	Internal GRC Auditor
Submission Date	25th Oct 2026

Table of Contents

1. Executive Summary

2. Introduction and Assessment Objectives

3. Scenario, Scope, and Limitations

4. Lab Environment, Tools, and Methodology

5. Phase 1: Discovery and Enumeration

6. Phase 2: Vulnerability Identification

7. Phase 3: Risk Assessment and Triage

7.3 Likelihood, impact, and inherent risk scoring

8. GRC and Compliance Framework Mapping

9. Remediation and Follow-Up Plan

10. Conclusion and Learning Outcomes

11. References

Item	Details
Report title	Lab 1: Practical Vulnerability Assessment for GRC Professionals
Role	Internal GRC auditor
Assessment purpose	Identify exposed services and potential security weaknesses, assess risk, map relevant control themes, and recommend remediation
Assessment target	Metasploitable lab server; target IP intentionally omitted from this report
Assessment workstation	Kali Linux

1. Executive Summary

Vulnerability assessment is an essential risk identification activity that helps organisations discover weaknesses in their information systems before those weaknesses can be exploited or lead to business disruption. From a Governance, Risk and Compliance (GRC) perspective, the purpose extends beyond identifying technical vulnerabilities; it involves evaluating how observed weaknesses could affect the confidentiality, integrity, and availability of organisational information assets, assessing their potential business impact, and recommending appropriate risk treatment measures.

This assessment was conducted against an intentionally vulnerable Metasploitable test server within an authorised, isolated development lab environment. The objective was to identify exposed network services and potential vulnerabilities, evaluate their associated risks, consider relevant security-control requirements, and provide management with evidence-based recommendations for remediation. The assessment used Nmap for network discovery and service enumeration, Nikto for web-server security testing, and Nuclei for additional template-based vulnerability scanning.

Nmap identified 30 open TCP ports and detected a range of services, including FTP, SSH, Telnet, remote shell and login services, SMB/Samba, NFS, database services, web servers, and other remotely accessible applications. The scan also identified legacy software versions and a service on TCP port 1524 reported as a Metasploitable root-shell listener. These observations indicate a broad attack surface requiring further investigation, particularly where services are unnecessary, outdated, or insufficiently restricted. Nikto identified potential web-server weaknesses, including directory indexing, an accessible PHP diagnostic page, accessible phpMyAdmin resources, an enabled HTTP TRACE method, missing recommended security headers, and legacy PHP and Apache version information.

The findings identify several areas of potential business risk, including unauthorised access, information disclosure, exposure to vulnerabilities affecting legacy software, and possible system compromise. The findings have been documented in a risk assessment register and prioritised according to their potential likelihood and impact. Risk ratings remain provisional where exploitability, software build, or configuration has not been independently confirmed. In particular, the detected vsftpd 2.3.4 version requires validation before the applicability of CVE-2011-2523 can be established.

Based on the assessment results, the key recommendations are to investigate potentially privileged services, validate and remediate vulnerable or unsupported software, disable unnecessary network services, restrict access to administrative and database interfaces and strengthen web-server configuration. Remediation should be supported by assigned responsibilities, target completion dates, a maintained risk register, and follow-up testing to verify that corrective actions are effective.

The findings have also been considered against relevant security-control themes in the NIST Cybersecurity Framework (CSF) 2.0, CIS Critical Security Controls v8.1, and applicable web-security guidance. PCI DSS should be considered only where the assessed system falls within the scope of payment-card data requirements. This mapping supports control review and remediation planning; it does not, by itself, establish formal non-compliance.

In conclusion, the assessment demonstrates how vulnerability assessment supports risk identification, risk prioritisation, and informed management decision-making. By translating

technical observations into potential business consequences and actionable recommendations, GRC professionals can help organisations reduce their attack surface, strengthen security controls, and improve accountability for risk treatment. The results provide a basis for remediation and further validation within the lab environment, with final risk decisions dependent on verification of the identified issues.

2. Introduction and Assessment Objectives

2.1 Introduction

Technical vulnerability assessment is a supporting activity within cybersecurity governance and risk management. For GRC professionals, the value of scanning is not limited to listing ports or scanner alerts; it also involves determining what the evidence means, how a weakness could affect an organisation, which controls may be relevant, and what action is needed to reduce risk. This report translates the lab's technical results into structured observations and management-focused recommendations.

The assessment was performed on Metasploitable, an intentionally vulnerable test server, using the lab's prescribed tools.

2.2 Objectives

The lab aimed to:

- Confirm that the authorised lab target was reachable.
- Identify open TCP ports, services, service versions, and an operating-system estimate.
- Review Nmap output and preserve results in readable, structured, and HTML formats.
- Assess the target's HTTP service using Nikto and document its reported observations.
- Attempt focused vulnerability scanning with Nuclei.
- Classify significant observations using the lab's inherent-risk criteria.
- Connect relevant observations to recognised security-control and compliance themes.
- Recommend practical remediation and follow-up validation steps.
- Maintain a clear distinction between scanner observations, verified vulnerabilities, and limitations in assessment coverage.

3. Scenario, Scope, and Limitations

3.1 Scenario

The assessment simulates an internal audit of a newly discovered Metasploitable server within a development environment. The task is to identify potential vulnerabilities and explain their implications for security risk and control effectiveness.

3.2 In scope

- Connectivity verification to the designated Metasploitable target.
- Nmap TCP port scanning, service/version detection, default scripts, and operating-system detection.
- Review of Nmap .nmap, .gnmap, .xml, and generated HTML output.
- Nikto assessment of the target's HTTP service.
- Nuclei scanning
- Risk assessment and high-level mapping to GRC frameworks.
- Recommendations for remediation and validation.

3.3 Out of scope

- Scanning any public, production, organisational, or third-party system.
- Exploitation beyond the authorised lab tasks documented in the evidence.
- Confirmation of credentials or password strength where no test evidence was supplied.
- A formal PCI DSS assessment, ISO/IEC 27001 certification audit, or complete penetration test.
- A conclusive vulnerability determination for every legacy service based solely on a version banner.

3.4 Limitations

- Service/version detection and scanner output can be incomplete or inaccurate and may require manual verification.
- Nmap's operating-system identification is an estimate, not definitive proof of the exact kernel build.
- Some Nikto observations are informational or configuration-related and do not necessarily represent exploitable vulnerabilities.
- References to CVEs in scanner output have not all been independently confirmed against the exact target build.

4. Lab Environment, Tools, and Methodology

4.1 Environment

Component	Description
Assessment workstation	Kali Linux
Target	Metasploitable intentionally vulnerable test server
Network context	Authorised isolated lab network
Nmap	Used for discovery, port/service enumeration, version detection, and OS estimation; precise version not recorded in the supplied notes
Nikto	Version 2.6.1, according to the supplied lab notes/output context
Nuclei	Version 3.11.1
xsltproc	Used to create an HTML view of Nmap XML output
Browser	Firefox, for reviewing web resources and HTML report

4.2 Methodology

The assessment followed the three phases specified in the assignment:

Phase 1 — Discovery and enumeration: Verify target reachability, scan all TCP ports, enumerate services and versions, and generate output files and an HTML report.

Phase 2 — Vulnerability identification: Review Nmap findings, run Nikto against the HTTP service, and attempt focused Nuclei scans.

Phase 3 — Analysis and reporting: Triage observations, assign provisional inherent-risk ratings, map relevant control themes, produce management recommendations, and document evidence and limitations.

4.3 Tool reliability and evidence confidence

Nmap

Nmap provides host discovery, port state, service and version probes, scripts and operating-system fingerprinting. The reported service/version strings are useful inventory evidence, but the Nmap documentation cautions that service identification is based on probes and signatures and may not always be definitive [1]. OS match confidence of 100% is a tool estimate, not proof of a complete or fully patched OS identity.

Nikto

Nikto tests web servers for common files, unsafe defaults, versions and configuration patterns. The supplied output reports 8,235 requests, zero request errors and 31 items. Some results are observations (e.g., directory listing and phpinfo output); others are recommendations or possible conditions and need validation. The update-check error did not stop the scan. The two pasted summaries are nearly identical and should not be counted as two separate sets of vulnerabilities.

Nuclei

Nuclei is template-based: the engine loads YAML templates and reports matches that satisfy a template's conditions . An earlier run failed because no templates were available; its “No results found” was not a clean scan. The later saved output contains two lines, so the report treats these as target-specific Nuclei results, while still distinguishing a version/EOL template from an exploit-confirmation test.

4.4 Risk-rating approach

These lab's inherent-risk criteria are used:

- High (H): Potentially easy to exploit and capable of resulting in full system compromise or similarly significant impact.
- Medium (M): May require additional skill or conditions and could result in data leakage or unauthorised access.
- Low (L): Primarily information disclosure or lower-impact security weaknesses.

5. Phase 1: Discovery and Enumeration

5.1 Step 1 — Network discovery

A four-packet ping check was performed against the target using the lab command:

```
ping -c 4 192.168.**.***
```

Result: The connectivity check succeeded according to the recorded lab results. The target IP is omitted from this public-facing report.

GRC interpretation: Asset discovery is a foundation for asset inventory and risk management. Systems that are unknown or not represented in an asset inventory can be missed by vulnerability management, monitoring, and access-control processes. Discovery alone does not establish ownership or authorisation; discovered assets should be matched to an approved inventory.

5.2 Step 2 — Nmap port and service enumeration

The all-TCP-port scan used the following command pattern, with the authorised target address substituted locally:

```
nmap -sV -sC -O -p- -oA initial_scan 192.168.**.***
```

The options request service/version detection (-sV), default scripts (-sC), operating-system detection (-O), all TCP ports (-p-), and output in three formats (-oA). The XML file was converted to HTML with:

```
xsltproc -o initial_scan_report.html \
  /usr/share/nmap/nmap.xsl initial_scan.xml
```

Recorded result: Nmap identified 30 open TCP ports. Its operating-system output indicated a Linux 2.6-series system, with a possible kernel range of 2.6.9–2.6.33.

5.3 Open-port and service inventory

The following table transcribes the 30 open TCP entries in the supplied Nmap output. Version banners and service identifications should be validated before they are used as the basis for a definitive vulnerability claim.

Port	State	Service	Detected version / Nmap detail

21/tcp	Open	FTP	vsftpd 2.3.4
22/tcp	Open	SSH	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp	Open	Telnet	Linux telnetd
25/tcp	Open	SMTP	Postfix smtpd
53/tcp	Open	DNS	ISC BIND 9.4.2
80/tcp	Open	HTTP	Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp	Open	RPC	rpcbind 2 (RPC #100000)
139/tcp	Open	NetBIOS/SMB	Samba smbd 3.X–4.X; workgroup WORKGROUP
445/tcp	Open	SMB	Samba smbd 3.0.20-Debian; workgroup WORKGROUP
512/tcp	Open	Remote execution	netkit-rsh rexecd
513/tcp	Open	Remote login	OpenBSD or Solaris rlogind (Nmap fingerprint)
514/tcp	Open	Remote shell	Netkit rshd
1099/tcp	Open	Java RMI	GNU Classpath grmiregistry

1524/tcp	Open	Bindshell	Identified by Nmap as “Metasploitable root shell”
2049/tcp	Open	NFS	Versions 2–4
2121/tcp	Open	FTP	ProFTPD 1.3.1
3306/tcp	Open	MySQL	5.0.51a-3ubuntu5
3632/tcp	Open	distccd	distccd v1, GNU 4.2.4 (Ubuntu 4.2.4-1ubuntu4)
5432/tcp	Open	PostgreSQL	PostgreSQL DB 8.3.0–8.3.7
5900/tcp	Open	VNC	VNC protocol 3.3
6000/tcp	Open	X11	Access denied
6667/tcp	Open	IRC	UnrealIRCd ; version not established in supplied table
6697/tcp	Open	IRC	UnrealIRCd; version not established in supplied table
8009/tcp	Open	AJP	Apache JServ Protocol v1.3
8180/tcp	Open	HTTP	Apache Tomcat/Coyote JSP engine 1.1
8787/tcp	Open	Ruby DRb	Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)

45552/tcp	Open	RPC mountd	Versions 1–3 (RPC #100005)
48741/tcp	Open	RPC lock manager	Versions 1–4 (RPC #100021)
50703/tcp	Open	Java RMI	GNU Classpath grmiregistry
55353/tcp	Open	RPC status	Version 1 (RPC #100024)

5.4 GRC interpretation

The service inventory indicates several risk areas for review:

- Attack-surface management: 30 open TCP ports create a need to confirm the business requirement for every service and close unnecessary exposure.
- Remote administration: Telnet, rsh, and rlogin are legacy protocols and should not normally be exposed when secure alternatives are available.
- Data-store exposure: MySQL and PostgreSQL were detected as listening services. The scan does not prove that these services are reachable from outside the lab network or that authentication can be bypassed; their reachability and access controls require review.
- Legacy components: Several detected software versions are old and warrant support-status and patch-level verification.
- Potentially high-impact service: The service identified on port 1524 requires priority verification because the Nmap label associates it with a root shell.
- Further validation required: Java RMI, distccd, VNC, AJP, Ruby DRb, NFS, RPC, SMB, and IRC services should be investigated for necessity, access restrictions, and applicable vulnerabilities rather than assumed exploitable solely because they are open.

Open ports are not automatically compliance breaches. The compliance concern arises when an exposed service is unnecessary, inadequately controlled, inconsistent with the system's approved baseline, or violates a requirement that applies to the environment.

6. Phase 2: Vulnerability Identification

6.1 Step 3 — Nmap result analysis

The Nmap output and generated HTML report were reviewed for detected service names, version strings, and unusual service exposure. These results formed the basis for the inventory in Section 5.3 and for prioritising further review. No separate evidence of successful exploitation was supplied.

6.2 Step 4 — Nikto web-server assessment

Nikto was run against the target's HTTP service using the following command pattern:

```
nikto -h http://192.168.**.*** -o nikto_scan.txt
```

The supplied Nikto output included the observations below. The risk comments indicate plausible impact and required validation, rather than a claim that exploitation has been demonstrated.

ID	Nikto observation	Potential impact / interpretation	Recommended treatment
WEB-01	X-Powered-By disclosed PHP 5.2.4-2ubuntu5.10; Nikto described PHP 5.2.4 as outdated	Technology disclosure and potential exposure to weaknesses affecting unsupported software	Verify installed package/build and upgrade to a supported version where feasible
WEB-02	Apache httpd 2.2.8 reported as outdated	Legacy web-server software may contain unpatched weaknesses	Confirm the actual package and support state; upgrade or replace
WEB-03	Directory indexing reported on /icons/, /doc/, and /test/	Directory contents or filenames may be disclosed; sensitivity	Disable indexing where not needed and

		depends on contents and access	remove or restrict unnecessary content
WEB-04	/phpinfo.php returned output from PHP phpinfo(); Nikto referenced CWE-552	Detailed configuration output can support attacker reconnaissance	Remove the diagnostic page or restrict it to authorised administrators
WEB-05	/phpMyAdmin/changelog.php, /phpMyAdmin/ChangeLog, /phpMyAdmin/Documentation.html, and /phpMyAdmin/README were accessible	Database administration resources and documentation may be exposed; this does not itself prove administrative login is possible	Restrict phpMyAdmin to authorised users and networks; remove unused resources
WEB-06	HTTP TRACE was enabled and responded	May increase exposure to certain cross-site tracing scenarios, depending on the application and client environment	Disable TRACE if there is no documented requirement and verify after remediation
WEB-07	Nikto reported missing X-Content-Type-Options, Referrer-Policy, Permissions-Policy, Strict-Transport-Security, and Content-Security-Policy headers	Missing headers may reduce browser-side, defence-in-depth protections; HSTS applicability depends on HTTPS use	Review the application and deployment model; configure suitable headers and test for functional impact
WEB-08	Apache MultiViews was enabled and index.php was identified as an alternative for /index	May make alternate resource names easier to discover in some configurations	Review whether content negotiation is required; disable if unnecessary

WEB-09	PHP Easter Egg query responses were reported	May disclose unnecessary PHP or implementation details	Disable the feature where applicable and verify the responses no longer reveal extra information
WEB-10	/icons/README was identified as an Apache default file	Default content may disclose implementation details	Remove unnecessary defaults or restrict access
WEB-11	An uncommon TCN header with value list was reported	May reveal server negotiation behaviour; relevance depends on context	Review the header and configuration; retain only if required
WEB-12	A response to a non-standard method string (RDEEKDPP, as displayed in the supplied output) was reported	May indicate unusual handling of HTTP methods or a scanner false positive	Validate manually and review accepted methods and server logs
WEB-13	Nikto reported ETag metadata for /phpMyAdmin/ChangeLog, including an inode, size, and modification time; it cited CVE-2003-1418	May disclose file metadata; applicability of the cited CVE is not established by the scan alone	Verify the server behaviour and reference applicability; minimise unnecessary metadata where appropriate
WEB-14	Nikto associated browseable /doc/ with CWE-548 and referenced CVE-1999-0678	Potential directory disclosure; the scanner reference requires context-specific validation	Confirm whether sensitive content is exposed and remove/restrict unnecessary documentation

WEB-15	Nikto raised a note about X-Frame-Options and modern Content-Security-Policy framing controls	Framing protection should be reviewed for the actual application; the scanner's wording is not itself proof of exploitation	Configure a suitable frame-ancestors directive and/or compatible header according to application needs

The Nikto output also noted that server responses to unusual methods may cause false positives. Therefore, findings should be confirmed manually where practicable. A scanner reference to a CVE is not a verified finding unless the affected product/version and conditions match.

Web assessment conclusion

Nikto identified several plausible configuration and information-disclosure issues requiring remediation review. The highest-value actions are to remove the diagnostic page, restrict database administration resources, disable unneeded directory indexing and HTTP methods, and replace unsupported web-server components. Header recommendations should be tailored to the application's actual HTTPS and browser-security requirements; the absence of a header is not automatically a severe vulnerability in every deployment.

6.3 Step 5 — Nuclei focused vulnerability scanning

The lab instructions called for web-focused and broader Nuclei scans using commands:

```
nuclei -u http://192.168.**.*** -o nuclei_web_scan.txt
nuclei -target 192.168.**.*** -o nuclei_full_scan.txt
```

Nuclei v3.11.1 was installed. During the attempt,it initially stated that the tool could not find the expected template path under /home/kali/.local/nuclei-templates. But new templates was downloaded and it was resolved

Assessment Findings: CVE-2012-1823 High; CVE-2026-109618 version/EOL branch Critical

High-priority PHP exposure; confirm configuration and CVE applicability

GRC framing

Asset discovery supports knowing which systems need protection. Vulnerability identification supports risk analysis. Prioritisation helps management decide what to fix first. Evidence collection provides traceability. Retesting provides assurance that a control

action worked. The value of this exercise is the end-to-end link from technical observation to accountable risk treatment.

7. Phase 3: Risk Assessment and Triage

7.1 Assessment approach

The risk register below prioritises material observations by plausible impact and exposure. It includes the CVE/reference where a reference was provided or is relevant for verification. A rating of High is provisional where the finding could result in substantial compromise if confirmed. Medium and Low ratings similarly require validation against actual configuration and business context.

The “control relevance” column identifies potential framework/control themes. It does **not** assert that a formal compliance breach has been established. The assessor should document the applicable framework version, scope, requirement, and evidence before making a compliance determination.

8. Consolidated risk register - part 1

Ratings are provisional inherent-risk priorities derived from the supplied evidence and a simplified likelihood-impact model. Scanner severity and auditor priority are shown separately where relevant. “Confidence” reflects the evidence currently available, not the severity of the potential impact.

ID / finding	Evidence and confidence	Provisional risk	Required treatment
F-01 PHP CGI argument injection (CVE-2012-1823)	Nuclei reports a High match at /index.php with CGI-style query string. High confidence in reported match; configuration confirmation pending.	High; elevate to Critical if CGI applicability is confirmed	Validate safely; disable vulnerable CGI path or migrate PHP stack; retest.

F-02 PHP2Shell / EOL branch (CVE-2026-109618)	Nuclei version/EOL branch match shows PHP 5.2.4-2ubuntu5.10. Medium confidence for this specific CVE applicability; high confidence in EOL version disclosure.	Critical triage priority for unsupported PHP; exact CVE path not directly proven	Isolate; inventory server-side PHP deployment; migrate to vendor-supported fixed branch; verify.
F-03 Legacy Apache/PHP and diagnostic pages	Nikto/Nmap show Apache 2.2.8, PHP 5.2.4, phpinfo.php, old documentation/default files. High confidence in observed disclosure.	High	Rebuild/upgrade; remove diagnostics/default files; patch and retest.
F-04 Anonymous FTP / vsftpd	Nmap reports anonymous login and plaintext connections; vsftpd 2.3.4 banner. High confidence in banner/anonymous access; low-medium for CVE-2011-2523 applicability.	High	Disable anonymous FTP unless approved; verify package provenance; replace service.
F-05 Telnet/rlogin/rexec/rsh	Nmap lists ports 23, 512-514 open. High confidence in service exposure.	High	Disable or restrict; use approved secure remote administration.
F-06 Root-shell-labelled service	Port 1524 identified as Metasploitable root shell. High confidence in scanner fingerprint; actual privilege path not tested.	Critical	Maintain isolation; verify within lab rules; disable on any non-lab asset.

F-07 SMB, database, NFS/RPC exposure	445 signing disabled; MySQL/PostgreSQL/NFS/RPC listeners open; versions old. High confidence in exposure; access exploitability unverified.	High	Limit network sources, patch/rebuild, review permissions and signing.

ID / finding	Evidence and confidence	Provisional risk	Required treatment
F-08 Web directory listing and phpinfo	Nikto flags /icons/, /doc/, /test/ and /phpinfo.php. High confidence in scanner observation.	High	Disable indexes; delete/restrict diagnostics, test content and unnecessary documentation.
F-09 phpMyAdmin-related files	Nikto detects changelog, ChangeLog, Documentation and README under /phpMyAdmin. High confidence that paths respond; admin bypass not proven.	High if administration interface is reachable; otherwise Medium	Restrict admin interface; verify authentication, access paths and package age.
F-10 SMTP SSLv2 / expired certificate	Nmap reports SSLv2 supported on port 25 and certificate valid dates ending 16 Apr 2010. High	High	Disable obsolete protocols; replace cert as appropriate; restrict SMTP exposure.

	confidence in script output.		
F-11 HTTP hardening weaknesses	Nikto flags TRACE, missing headers, MultiViews and ETag inode metadata. High confidence for reported responses; impact varies.	Medium to High	Disable unnecessary methods; implement context-appropriate headers; validate ETag exposure.
F-12 Tomcat/AJP and Java/DRb services	Nmap reports Tomcat 5.5 on 8180, AJP on 8009, Java RMI on 1099/51913 and Ruby DRb on 8787. High confidence in exposure.	High	Remove unsupported components or isolate; limit listener access; patch/migrate.
F-13 DNS, IRC, VNC, X11 and distccd	Ports 53, 5900, 6000, 3632, 6667/6697 and RPC dynamic ports respond. High confidence in exposure.	Medium to High	Confirm business need, restrict to trusted peers and assess versions/authentication.
F-14 Insecure/weak credentials	No password audit, login test or credential evidence supplied.	Not rated - not assessed	Do not claim as a finding. Review password/access controls only if separately authorised.

8.1 Consolidated risk assessment register

ID	Finding / affected service	CVE or reference	Inherent risk	Potential control relevance	Business impact and recommended response
RA-01	Service identified as a Metasploitable root shell on TCP/1524	Nmap service identification; manual validation required	High, provisional	Secure configuration, least privilege, access control; CIS Controls 4 and 6 themes	If confirmed reachable and privileged, unauthorised host control, data exposure, modification, or disruption. Investigate immediately; keep isolated; disable or restrict if unnecessary; retain verification evidence.
RA-02	FTP on TCP/21, vsftpd 2.3.4	CVE-2011-2523 applies to a specific backdoored distribution downloaded 2011-06-30 to 2011-07-03	High, provisional	Vulnerability management and secure configuration; CIS Controls 2, 4, and 7 themes	Potential remote compromise if the affected build is present and exploitable. Verify package/build; patch, replace, or disable as appropriate; retest.

RA-03	Telnet and traditional rsh/rlogin services on TCP/23, 512–514	Protocol/service observations; no separate CVE assigned	High, provisional	Access control and protection of data in transit; CIS Controls 4 and 6 themes	Potential credential/session exposure and unauthorised access, depending on reachability and configuration. Disable if unnecessary; use secure administration; restrict management access.
RA-04	Legacy Apache 2.2.8 and PHP 5.2.4 version banners	Version banners; specific vulnerability mapping not confirmed	High, provisional	Software inventory, vulnerability management, secure configuration; CIS Controls 2 and 7 themes	Potential exposure to known weaknesses if affected software is present and unpatched. Validate installed versions/support status, update or replace, and repeat scan.
RA-05	Database listeners: MySQL TCP/3306 and PostgreSQL TCP/5432	Nmap version observations	High, provisional; exposure/authentication not validated	Access control, network segmentation, secure configuration	Potential unauthorised data access or service compromise if reachable and inadequately protected. Restrict to

					required clients, review authentication, patch, and check network rules.
RA-06	SMB/Samba services on TCP/139 and 445	Detected Samba banners; applicable vulnerability not verified	High, provisional	Asset/software inventory, vulnerability management, least privilege	Potential file-share exposure or exploitation if the build/configuration is vulnerable. Validate build and share permissions; patch; restrict network access.
RA-07	Java RMI, distccd, VNC, AJP/Tomcat, Ruby DRb, NFS and RPC services	Exposed services as enumerated by Nmap; no specific exploit confirmed	High, provisional for exposure review	Attack-surface reduction, secure configuration, access management	Potential additional attack paths or access to internal resources. Confirm business need, restrict to trusted hosts, disable unused services, and verify versions/configuration.
RA-08	UnrealIRCd on TCP/6667 and 6697	Version not established in	Medium, provisional	Software inventory and vulnerability	Potential service compromise if a vulnerable build/configuration is present.

		supplied output		management	Identify exact build/configuration; patch or disable if unnecessary.
RA-09	Directory indexing on /icons/, /doc/, /test/	Nikto; CWE-548 reference; CVE-1999-0678 cited by scanner and requires verification	Medium, provisional	Secure configuration and information protection	Unnecessary discovery of files, paths, or documentation. Disable indexing; review content and restrict sensitive paths.
RA-10	Publicly accessible phpinfo.php	Nikto; CWE-552 reference from scanner	Medium, provisional	Secure configuration and information-disclosure controls	Disclosure of PHP/system configuration useful for reconnaissance. Remove the page or restrict access; retest.
RA-11	phpMyAdmin changelog/documentation/readme resources accessible	Nikto observations	Medium, provisional	Access control and administrative-interface protection	Increased visibility of database administration resources and software details. Restrict phpMyAdmin access and remove unused files.

RA-12	HTTP TRACE responds	Nikto observation; XST concern cited by scanner	Medium, provisional	Web hardening and access/data-protection practices	Additional HTTP attack surface; impact depends on application/client environment. Disable if unnecessary and validate allowed methods.
RA-13	Missing recommended web security headers	Nikto observations for X-Content-Type-Options, Referrer-Policy, Permissions-Policy, HSTS, and CSP	Low–Medium, provisional	Secure configuration and defence in depth	Reduced browser-side protections depending on deployment. Define suitable headers and test; apply HSTS only with appropriate HTTPS deployment.
RA-14	Apache MultiViews enabled; TCN header observed	Nikto observation; scanner cited an X-Force reference for MultiViews	Low–Medium, provisional	Secure configuration	May ease resource discovery or reveal negotiation behaviour. Validate relevance and disable unnecessary content negotiation.

RA-15	ETag metadata and default Apache README exposed	Nikto observations; CVE-2003-1418 cited by scanner but not independently confirmed	Low–Medium, provisional	Information disclosure and secure configuration	Exposure of file metadata or default implementation details. Validate behaviour; remove default content and minimise unnecessary metadata.
RA-16	Nuclei output files empty because template directory was unavailable	Nuclei terminal log and zero-byte output files	Not a vulnerability rating; assurance gap	Assessment completeness, evidence quality, vulnerability-management process	Assessment may lack additional findings until template-based scanning is completed. Configure templates, rerun the authorised scan, review results, and append verified findings.

8.2 Likelihood, impact, and inherent risk scoring

Likelihood and impact are assessed separately before assigning an inherent risk rating. These are qualitative, evidence-based judgments rather than statistically calculated probabilities. The scores are provisional because exploitability, full configuration, and compensating controls were not independently validated.

Likelihood. High: strong evidence indicates the condition is exposed and likely to be exploitable under the relevant conditions. Medium: a service or issue was observed, but exploitability, exact build, authentication, or deployment conditions still require validation. Low: the evidence is indirect, weak, or not reproduced.

Impact. High: potential for major system compromise, privileged access, serious data exposure, or substantial service disruption. Medium: meaningful information disclosure, administrative-interface exposure, or additional attack surface with harm dependent on context. Low: limited information disclosure or a defence-in-depth weakness with no material impact established.

Inherent risk. The estimated risk before crediting unverified mitigating controls; it is not residual risk. The qualitative scoring logic used here is: High likelihood + High impact = High; Medium likelihood + High impact = High; Medium + Medium = Medium; Medium + Low = Low–Medium; and Low + Low = Low. A high-impact finding may remain High even where likelihood is only Medium, when the potential consequence is substantial and the issue requires timely validation.

The following scores correspond to the finding IDs in the consolidated risk register. They should be revisited after manual validation, review of the target configuration, and verification of remediation.

Finding ID	Likelihood	Impact	Inherent risk
RA-01	Medium	High	High
RA-02	Medium	High	High
RA-03	Medium	High	High
RA-04	Medium	High	High
RA-05	Medium	High	High
RA-06	Medium	High	High
RA-07	Medium	High	High
RA-08	Medium	Medium	Medium

RA-09	Medium	Medium	Medium
RA-10	Medium	Medium	Medium
RA-11	Medium	Medium	Medium
RA-12	Medium	Medium	Medium
RA-13	Medium	Low	Low–Medium
RA-14	Medium	Low	Low–Medium
RA-15	Medium	Low	Low–Medium

8.3 Important triage notes

- Weak/default credentials: The lab brief gives weak default credentials as an example, but the evidence reviewed for this report does not show that credentials were tested or discovered. This is therefore not recorded as a confirmed finding.
- CVE-2011-2523: The CVE is associated with a particular backdoored vsftpd 2.3.4 distribution. The Nmap banner warrants validation but is not sufficient, on its own, to confirm that exact build.
- CVE-1999-0678 and CVE-2003-1418: These references appeared in Nikto's output. Their applicability to the exact target and observed behaviour has not been independently confirmed.
- Compliance violations: The control mapping is preliminary. A formal violation should be declared only after comparing verified evidence with the exact requirement and confirming scope and applicability.

9. GRC and Compliance Framework Mapping

The following mapping identifies control themes that could be relevant to the recorded observations. It is an initial cross-reference to guide remediation—not a compliance audit or certification assessment.

Observation / risk theme	NIST CSF 2.0 outcome area	CIS Critical Security Controls v8.1 theme	Other relevant guidance / consideration
Unknown or insufficiently tracked target assets	Identify — Asset Management	Control 1: Inventory and Control of Enterprise Assets	Maintain an authorised asset inventory and define asset ownership
Old or unknown software versions	Identify — asset and risk assessment; Protect — Platform Security	Control 2: Inventory and Control of Software Assets; Control 7: Continuous Vulnerability Management	Verify packages, versions, support status, and applicable advisories
Unnecessary exposed ports and services	Protect — Platform Security; Govern/Identify risk decisions	Control 4: Secure Configuration of Enterprise Assets and Software; Control 12: Network Infrastructure Management	Define an approved secure baseline and restrict access by network and role
Legacy remote-access protocols and privileged listeners	Protect — Identity/Access and Platform Security outcomes	Control 5: Account Management; Control 6: Access Control Management; Control 4: Secure Configuration	Use secure administration methods, least privilege, and restricted management paths

Database service exposure	Protect — access-control and platform-security outcomes	Controls 4, 6, and 7	Confirm system boundaries, network ACLs, authentication, and data sensitivity
Directory indexing, diagnostic pages, exposed phpMyAdmin resources, and headers	Protect — Platform Security	Controls 4 and 7	OWASP Top 10:2025, particularly Security Misconfiguration; OWASP Web Security Testing Guide
Vulnerability assessment	Identify — risk assessment; Govern — roles and oversight	Control 7: Continuous Vulnerability Management; documentation and process ownership	Record tool limitations, complete testing, and preserve reproducible evidence
Potential cardholder-data scope	Applicable NIST and organisational risk outcomes	Relevant CIS safeguards as supporting practices	PCI DSS is applicable only when the system is within the cardholder data environment or can affect its security; review the current PCI DSS version and exact requirement
ISMS risk treatment and continual improvement	NIST CSF 2.0 cross-cutting risk management	CIS Controls governance and safeguard implementation	ISO/IEC 27001:2022 risk assessment and treatment, access control, and vulnerability-management processes, as applicable

9.1 Compliance interpretation

The open ports and Nikto observations may indicate areas where security controls should be reviewed, but they do not automatically establish non-compliance. For example, the PCI DSS requirements apply to relevant in-scope payment-card environments; their inclusion here does not mean that this training target handles cardholder data. Similarly, a missing HTTP header should be evaluated against the application's architecture and approved secure configuration rather than treated as a universal compliance breach.

When using this report for a formal audit, identify the exact framework edition and relevant safeguard or requirement, document the system scope, collect corroborating evidence, and record whether the control is implemented, partially implemented, not implemented, or not applicable.

10. Remediation and Follow-Up Plan

The actions below are prioritised for the lab scenario. Timeframes are suggested planning targets, not confirmed service-level commitments. If applied in a real production setting, containment and changes must follow approved incident, change-management, and business-continuity procedures.

Priority / suggested timing	Action	Suggested owner	Evidence required for closure
Immediate	Maintain isolation of the intentionally vulnerable Metasploitable target and investigate the service identified on port 1524	Lab administrator / system owner	Service identity and exposure review; configuration before and after change; follow-up scan
Immediate	Verify exact vsftpd package/build and determine whether the CVE-2011-2523 affected distribution is present	System administrator	Package/version evidence, trusted advisory comparison, and remediation/retest result
High	Review all 31 open ports and document business purpose, exposure, and	System/network administrator	Approved service inventory and

	control owner for each service		documented disposition for each service
High	Disable Telnet/rsh/rlogin and other unnecessary services; restrict required management access	System/network administrator	Service status, firewall/routing rules, and validation output
High	Verify versions and support status for Apache, PHP, databases, Samba, FTP, IRC, Tomcat/AJP, RMI, distccd, VNC, and other detected services	System/application owners	Version inventory, applicable vulnerability review, patch/upgrade records
High	Restrict MySQL/PostgreSQL and SMB/NFS to authorised hosts and appropriate accounts	Database and system administrators	Network access rules, account/permission review, and authorised connectivity tests
Medium	Remove or restrict phpinfo.php, phpMyAdmin resources, default documentation, and unnecessary directory content	Web/application administrator	Updated web root/configuration and authorised retest
Medium	Disable directory indexing and TRACE when not required; review MultiViews and other HTTP method handling	Web/application administrator	Configuration review and repeat Nikto/manual checks

Medium	Define and test a suitable header policy for CSP, X-Content-Type-Options, Referrer-Policy, Permissions-Policy, and HSTS where appropriate	Web/application administrator	Header validation and application functionality test
Follow-up	Restore the Nuclei template set and rerun the web-focused and broader scans against the authorised target	Assessment operator	Non-empty scan output, template availability evidence, and review of each result
Ongoing	Maintain a risk register, assign owners and target dates, record risk acceptance, and retain closure evidence	GRC/risk owner	Updated register, management decisions, and verification records

10.1 Remediation validation criteria

A finding should not be marked closed merely because a configuration change was made. Closure should be based on appropriate verification, such as a repeat scan, service check, access-control test, software-version evidence, or review of relevant logs. Where the risk cannot be fully removed, document the residual risk, compensating controls, decision owner, and approved acceptance period.

11. Conclusion and Learning Outcomes

The assessment progressed from target discovery to service enumeration, web-server checking, risk triage, framework mapping, and remediation planning. Nmap identified 31 open TCP ports and multiple legacy or administrative services. Nikto reported web-server configuration and information-disclosure concerns. The assessment also identified a material evidence limitation: Nuclei could not be verified as having completed a valid scan because its template directory was unavailable and its output files were empty.

The main risk-management priority is to validate potentially high-impact exposures, particularly the service identified on port 1524 and the exact vsftpd 2.3.4 build, then reduce

unnecessary service exposure and remediate confirmed software and web-configuration weaknesses. Remediation should be tracked to closure with named owners and verification evidence.

This lab reinforces that GRC work requires evidence-based interpretation rather than simply running security tools. A defensible report distinguishes confirmed results from hypotheses, assigns proportionate provisional risk ratings, connects observations to applicable control themes, and gives management clear actions. The report does not claim successful exploitation, confirmed weak credentials, zero vulnerabilities from Nuclei, or formal compliance breaches where the supplied evidence does not support those conclusions.

Learning outcomes demonstrated

- Network discovery and service enumeration using Nmap.
- Interpretation and documentation of legacy services and application versions.
- Web-server assessment and output preservation using Nikto.
- Recognition of a failed/incomplete scanner setup and accurate disclosure of the limitation.
- Development of a risk register using inherent-risk criteria.
- Translation of technical findings into business impact and remediation actions.
- Preliminary mapping of findings to NIST, CIS, OWASP, and conditionally applicable PCI DSS control themes.
- Evidence management, validation planning, and professional reporting.

11. References

Center for Internet Security. (2024). *CIS Critical Security Controls v8.1*. https://www.cisecurity.org/controls/v8-1

International Organization for Standardization. (2022). *ISO/IEC 27001:2022—Information security, cybersecurity and privacy protection—Information security management systems—Requirements*. https://www.iso.org/standard/27001

MITRE. (n.d.). *CWE-548: Exposure of information through directory listing*. https://cwe.mitre.org/data/definitions/548.html

National Institute of Standards and Technology. (n.d.). *CVE-2011-2523 detail*. National Vulnerability Database. https://nvd.nist.gov/vuln/detail/CVE-2011-2523

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST Cybersecurity White Paper 29). https://doi.org/10.6028/NIST.CSWP.29

Nmap Project. (n.d.). *Nmap reference guide*. https://nmap.org/book/man.html

OWASP Foundation. (2025). *OWASP Top 10:2025*. https://top10.owasp.org/2025/

OWASP Foundation. (n.d.). *Web Security Testing Guide, version 4.2*. https://owasp.org/www-project-web-security-testing-guide/

PCI Security Standards Council. (n.d.). *PCI Data Security Standard (PCI DSS) and document library*. https://www.pcisecuritystandards.org/standards/pci-dss/

ProjectDiscovery. (n.d.). *Nuclei vulnerability scanner*. https://projectdiscovery.io/nuclei

ProjectDiscovery. (n.d.). *Nuclei templates* [GitHub repository]. https://github.com/projectdiscovery/nuclei-templates

Sullo. (n.d.). *Nikto documentation*. GitHub. https://github.com/sullo/nikto/wiki/

AI Usage Declaration

Generative AI(ChatGPT) was used to assist with organising the lab material into a structured report, refining grammar and professional wording, improving table presentation, and AI was not treated as a source of lab evidence.